

Monitorização Contínua de um Sistema de Leilões P2P

Rui Carvalho Tiago Baganha João Silva

Universidade do Minho

2025–2026

- 1 Sistema Original & Requisitos de Segurança
- 2 Modelo de Ameaça STRIDE
- 3 Mapeamento MITRE ATT&CK / NIST SP 800-137
- 4 Análise de Ameaças com OSINT & CTI
- 5 Arquitetura de Monitorização
- 6 Proof of Concept — Cenários de Detecção
- 7 Conclusões & Recomendações

Propriedades de Segurança

- Anonimato (pseudónimos efémeros)
- Autenticidade (certificados X.509)
- Integridade (assinaturas + blockchain)
- Não repúdio (TSA + assinaturas)
- Temporalidade verificável

Componentes Principais

- **CA Server** — emissão de certificados X.509
- **TSA Server** — prova temporal (SHA-256)
- **Blockchain** — imutabilidade dos registos
- **Peer Server** — gestão da rede P2P
- **Login/Auction Client** — interface e autenticação

Foco da Monitorização

O CA Server é o elemento central de confiança — compromisso dos certificados afeta toda a cadeia de autenticação do sistema.

Modelo de Ameaça STRIDE

A análise STRIDE identifica quais os componentes do sistema afetados por cada categoria de ameaça.

Ameaça	CA Srv	TSA Srv	Peer Srv	Blockchain	Login Cl.	Auction Cl.	Canal P2P	Fich. Loc.	CA DB
Spoofing	x	x	x		x	x		x	
Data Tampering	x	x	x	x		x	x	x	x
Repudiation	x	x	x			x		x	
Info. Disclosure	x	x	x	x	x	x	x	x	x
Denial of Service	x	x	x	x		x	x	x	x
Elev. of Privilege	x		x					x	x

Tabela: Matriz STRIDE – Componentes Afetados

Modelo de Ameaça STRIDE

Para cada categoria de ameaça são identificados os ativos afetados e o respetivo impacto no sistema.

Categoria STRIDE	Ativos afetados	Descrição
Spoofing	TSA Server, Peer Server, Login Client, Auction Client, Ficheiros Locais	Personificação de utilizadores ou serviços através de credenciais comprometidas.
Data Tampering	CA Server, TSA Server, Peer Server, Blockchain, Auction Client, Canal P2P, CA Database	Alteração de mensagens, ficheiros locais ou registos de certificados.
Repudiation	CA Server, TSA Server, Auction Client	Negação de ações realizadas devido à ausência de registos verificáveis.
Information Disclosure	Todos os componentes	Exposição de chaves privadas, certificados ou dados do leilão.
Denial of Service	CA Server, TSA Server, Peer Server, Blockchain, Canal P2P	Indisponibilidade de serviços críticos do sistema.
Elevation of Privilege	CA Server, Peer Server, CA Database, Ficheiros Locais	Obtenção de privilégios elevados ou emissão fraudulenta de certificados.

Tabela: Descrição das Ameaças STRIDE

Mapeamento para Frameworks

STRIDE → MITRE ATT&CK → NIST SP 800-137

As ameaças identificadas foram mapeadas para o MITRE ATT&CK, identificando as TTPs relevantes, e para o NIST SP 800-137, definindo os controlos de monitorização contínua aplicáveis ao CA Server.

STRIDE	MITRE ATT&CK	NIST 800-137	Controlo Técnico
Spoofing	T1078 Valid Accounts T1036 Masquerading	AC-2, IA-2	Logging CSR; Autenticação TLS mútua
Data Tampering	T1565.001 Stored Data Manipulation T1553.004 Install Root Certificate	SI-7, AU-12	Verificação periódica de hash SHA-256
Repudiation	T1070 Indicator Removal	AU-6, AU-8	Logs imutáveis de emissão/revogação
Info. Disclosure	T1567 Exfiltration T1212 Credential Access	IA-5, AC-3	Encriptação CA DB; HSM
Denial of Service	T1498 Network DoS T1499 Endpoint DoS	SC-5, IR-5	Rate limiting CSR; Monit. latência
Elev. of Privilege	T1068 Privilege Escalation	AC-5, CM-5	Separação funções CA/TSA/Peer

Eventos, Métricas e Ações de Monitorização

Para cada ameaça STRIDE são definidos eventos monitorizáveis, métricas quantitativas, limiares de ativação e ações automáticas de resposta.

STRIDE	Evento	Métrica	Threshold	Ação
Spoofing	Falhas validação CSR	N.º falhas / IP	>5 em 2 min	Alerta + bloqueio IP
Data Tampering	Alteração na CA BD	Hash mismatch	1 ocorrência	Alerta CRITICAL + suspensão
Repudiation	Delete em registo emissão	Evento delete	1 ocorrência	Alerta CRITICAL + notif. admin
Info. Disclosure	Acesso BD não-admin	Acessos não-admin	1 ocorrência	Alerta CRITICAL + revogação
DoS	Pico de pedidos CSR	Pedidos / min	>100 / min	Rate limiting
Elev. Privilege	Certificado com ca=true	Certs. c/ atrib. CA	1 ocorrência	CRITICAL + revogação imediata

Tabela: Eventos, Métricas e Ações de Monitorização

Fontes consultadas

- MITRE ATT&CK
- CISA Advisories
- CERT/CC

Ameaças selecionadas

T1565.001 — Stored Data Manipulation

Adulteração de certificados de utilizadores na BD.
Caso real: Comodo CA 2011 — 9 certificados falsificados para Google, Yahoo e Skype.

T1553.004 — Install Root Certificate

Substituição do certificado raiz — controlo total da cadeia de confiança.
Caso real: DigiNotar 2011 — 500+ certificados fraudulentos, incluindo domínios governamentais iranianos.

Pipeline de Monitorização

Monitor Integridade → JSON Logs → **Filebeat** → **Elasticsearch** → **Grafana** → Email (SMTP)

Camadas funcionais

- **Recolha** — hash SHA-256
periódico + logging
aplicacional
- **Processamento** — Filebeat +
Elasticsearch
- **Armazenamento** —
centralizado e independente
- **Visualização** — Grafana
dashboards + alertas

IoCs monitorizados

- Hash SHA-256 divergente
CA cert → **CRITICAL**
User cert → **WARNING**
- Conexão externa ao
PostgreSQL por IP não
autorizado

Cenário 1 — Substituição do Certificado da CA

Indicadores

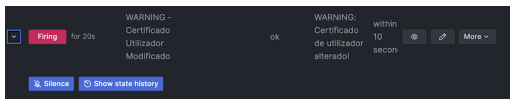
- ca_cert_tampered
- Severidade: **CRITICAL**
- Regra: **RULE-001**
- TTP: T1553.004

State	Name	Health	Summary	Next evaluation	Actions
Firing for 1m	CRITICO - Certificado CA Substituido	ok	CRITICO: Certificado foi substituido	MITRE ATT&C Technique: T1553.004 Stored Data Manipulation Tactic: Tampering within 10 seconds	  More ▾
			Regra: RULE-001: CERT_HASH_I		

Cenário 2 — Modificação de Certificado de Utilizador

Indicadores

- user_cert_tampered
- Severidade: **WARNING**
- Regra: **RULE-001**
- TTP: T1565.001



Cenário 3 — Ligação Externa e Exfiltração

Ligação externa

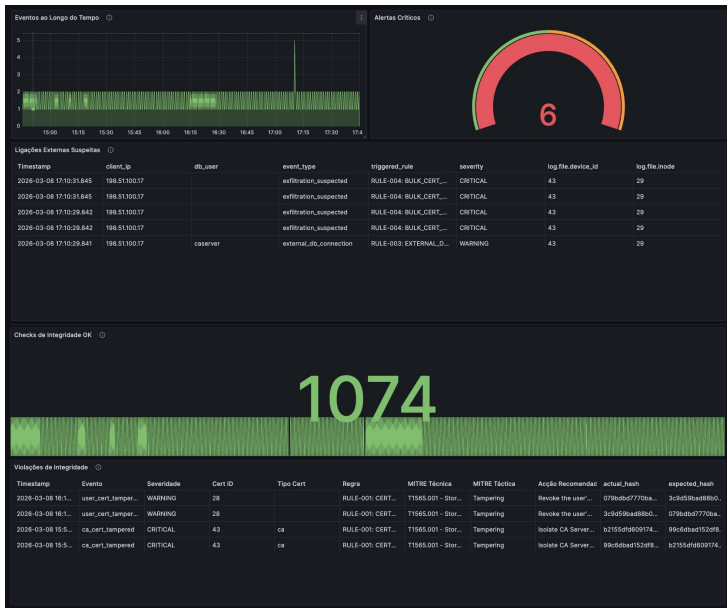
- `external_db_connection`
- Severidade: **WARNING**
- Regra: **RULE-003**

Exfiltração suspeita

- `exfiltration_suspected`
- Severidade: **CRITICAL**
- Regra: **RULE-004**

>	Firing	for 1m	WARNING - Ligacao Externa a BD	ok	WARNING: Ligacao externa detetada!	within 10 secon	  More v
>	Firing	for 1m	CRITICO - Tentativa de Exfiltracao	ok	CRITICO: Tentativa de exfiltracao!	within 10 secon	  More v

Dashboard de Monitorização



Conclusões & Recomendações

- ✓ A arquitetura deteta alterações maliciosas e acessos suspeitos ao CA Server com baixa latência.
- ✓ A integração de OSINT/CTI (MITRE ATT&CK, CISA, CERT/CC) traduziu TTPs reais em regras de deteção operacionais.
- ✓ O protótipo demonstra recolha (SHA-256), correlação (Elasticsearch), alerting (Grafana) e notificação (email SMTP).